

1.1 Project context (healthcare scenario)

Organization Overview HealthyLife Clinic is a mid-sized healthcare provider offering outpatient services, diagnostics, and telemedicine. The organization processes a large volume of patient health information (PHI), billing data, and internal operational data across multiple systems, including an electronic health record (EHR) platform, billing system, and patient portal.

1.2 Scope of the data classification program

Scope This data classification and handling program applies to all information assets processed, stored, or transmitted by HealthyLife Clinic, including:

- Patient health information (PHI)
- Electronic health records (EHR)
- Billing and insurance data
- Internal operational and administrative data
- IT system logs and configuration data

The program covers both **digital and physical** information, regardless of format or storage location (on-premises, cloud, or third-party systems).

1.3 Objectives of the program

Objectives The objectives of this data classification and handling program are to:

- Ensure that sensitive healthcare information, especially PHI, is appropriately protected.
- Support compliance with applicable regulations (e.g., healthcare privacy and security requirements).
- Provide clear guidance to staff on how to classify, store, transmit, share, and dispose of information.
- Enable risk-based protection of information assets based on their sensitivity and impact if compromised.

1.4 Assumptions (important for a portfolio project)

Assumptions

- This program is designed as a sample framework for a healthcare organization and uses fictional data and entities.
- The organization maintains an electronic health record (EHR) system, a billing platform, and a patient portal.

- The program focuses on defining classification levels and handling requirements, and does not include technical implementation details such as specific tools or configurations.

2. Data Classification Levels

2.1 Public

Definition: Information approved for public release that poses no risk to the organization or patients if disclosed.

Examples:

- Website content
- Public health education materials
- Job postings
- Press releases

2.2 Internal

Definition: Non-sensitive operational information intended for internal use only. Unauthorized disclosure may cause minor operational disruption but no patient harm.

Examples:

- Internal memos
- Staff schedules
- Training materials
- Internal project documentation
- Non-sensitive IT configuration notes

2.3 Confidential

Definition: Sensitive information that could cause harm to the organization or individuals if disclosed. This includes business, financial, and some clinical operational data.

Examples:

- Internal financial reports
- Vendor contracts
- Employee HR files
- Audit logs

- System configuration backups
- Non-identifiable clinical research data

2.4 Restricted (PHI / Highly Sensitive Clinical Data)

Definition: The highest-sensitivity category. Includes Protected Health Information (PHI) and any data that could cause significant harm, legal liability, or patient safety risk if compromised.

Examples:

- Electronic Health Records (EHR)
- Patient demographics
- Lab results
- Diagnostic images
- Treatment plans
- Insurance & billing data containing identifiers
- Prescription information
- Clinical notes
- Telemedicine session data
- Authentication secrets (API keys, encryption keys)

3. Data Classification Matrix

The Data Classification Matrix provides a consolidated view of all classification levels, their definitions, examples, and required protection measures. This matrix serves as a quick reference guide for staff and supports consistent application of data handling requirements across the organization.

4. Data Handling Requirements

4.1 Public Data — Handling Requirements

Storage

- Can be stored on any organizational system.
- No special security controls required.

Transmission

- Can be sent via email or shared publicly without restrictions.

Access

- Accessible to all staff and external parties.

Sharing

- No restrictions on distribution.

Logging & Monitoring

- No special monitoring required.

Disposal

- Standard deletion or recycling.

4.2 Internal Data — Handling Requirements**Storage**

- Must be stored on internal systems (e.g., internal drives, intranet).
- Not permitted on personal devices.

Transmission

- Allowed over internal networks or secure email.
- External sharing prohibited unless approved.

Access

- Access limited to employees and authorized contractors.

Sharing

- Internal sharing only; no public posting.

Logging & Monitoring

- Basic access logging recommended.

Disposal

- Delete using standard system deletion.
- Physical documents should be placed in secure disposal bins.

4.3 Confidential Data — Handling Requirements**Storage**

- Must be stored on secure systems with access controls.
- Encryption at rest recommended.

Transmission

- Must be encrypted in transit (TLS, secure email).
- External sharing requires manager approval.

Access

- Restricted to authorized personnel based on job role.
- Least-privilege principle applies.

Sharing

- Only shared with approved internal teams or vetted third parties.
- Requires confidentiality agreements when shared externally.

Logging & Monitoring

- Access must be logged.
- Periodic access reviews required.

Disposal

- Must be securely deleted (digital wiping).

- Physical documents must be shredded.

4.4 Restricted Data (PHI / Highly Sensitive Clinical Data) — Handling Requirements

This is the most important section for a healthcare organization.

Storage

- Must be stored only in approved clinical systems (EHR, billing system).
- Encryption at rest is mandatory.
- Backups must also be encrypted.

Transmission

- Must be encrypted end-to-end.
- PHI cannot be sent via standard email unless using secure messaging.
- No transmission through personal devices or unapproved apps.

Access

- Strict least-privilege access.
- Multi-factor authentication required.
- Access must be tied to clinical or operational need.

Sharing

- External sharing only with authorized healthcare partners.
- Requires patient consent where applicable.
- Must follow minimum necessary rule.

Logging & Monitoring

- All access must be logged.
- Real-time monitoring for unusual access patterns.
- Alerts for failed access attempts.

Disposal

- Secure wiping for digital data.
- Physical PHI must be shredded or incinerated.
- No disposal in regular trash.

Classification	Storage	Transmission	Access	Sharing	Disposal
Public	No restrictions	No restrictions	Open	Open	Standard
Internal	Internal systems	Internal/secure email	Employees	Internal only	Standard secure
Confidential	Secure systems, encryption	Encrypted	Authorized staff	Controlled	Secure deletion
Restricted (PHI)	Encrypted clinical systems	Encrypted only	MFA + least privilege	Strictly controlled	Secure destruction

5. Roles and Responsibilities

5.1 Data Owner

Definition: A senior individual responsible for a specific data set or business process.

Responsibilities:

- Determine the appropriate classification level for their data.
- Approve access requests based on job role and necessity.
- Ensure data handling requirements are followed.
- Review access rights periodically.
- Work with IT and Compliance to ensure proper safeguards are in place.

Healthcare examples:

- Director of Clinical Operations (EHR data)
- Billing Manager (insurance & claims data)
- HR Manager (employee data)

5.2 Data Custodian

Definition: IT or system administrators responsible for implementing and maintaining technical controls.

Responsibilities:

- Enforce access controls and permissions.
- Implement encryption, backups, and secure storage.
- Maintain system logs and monitoring tools.
- Support secure data transmission and storage.
- Report security incidents to the Security/Compliance team.

Healthcare examples:

- EHR system administrators
- IT infrastructure team
- Cloud platform administrators

5.3 Data User

Definition: Any employee, contractor, or clinician who accesses or handles organizational data.

Responsibilities:

- Follow the data classification and handling requirements.
- Access only the data required for their job role.
- Report suspected data breaches or improper access.
- Complete mandatory privacy and security training.
- Protect PHI and follow the minimum necessary rule.

Healthcare examples:

- Nurses
- Physicians
- Billing staff
- Front-desk staff
- IT support technicians

5.4 Compliance Officer / Privacy Officer

Definition: The individual responsible for ensuring regulatory compliance and privacy protection.

Responsibilities:

- Oversee compliance with healthcare privacy and security regulations.
- Conduct periodic audits of data handling practices.
- Investigate and report privacy incidents.
- Maintain policies and update them as regulations evolve.
- Provide training and awareness programs.

Healthcare examples:

- HIPAA Privacy Officer
- Security & Compliance Manager
- Internal Auditor (for oversight)

5.5 Information Security Team

Definition: The team responsible for implementing and monitoring security controls.

Responsibilities:

- Monitor access logs and detect unusual activity.
- Respond to security incidents.
- Conduct risk assessments and vulnerability reviews.
- Support encryption, MFA, and secure configurations.
- Work with Data Owners to ensure controls match classification levels.

Healthcare examples:

- SOC analysts
- Security engineers
- Incident response team

5.6 Clinical Staff

Definition: Healthcare professionals who interact with PHI daily.

Responsibilities:

- Access PHI only when required for patient care.
- Follow secure handling and disposal procedures.
- Protect patient privacy during clinical operations.
- Report any suspected unauthorized access or disclosure.

Healthcare examples:

- Doctors
- Nurses
- Lab technicians
- Pharmacists

5.7 Third-Party Service Providers

Definition: Vendors or partners who process or store healthcare data.

Responsibilities:

- Comply with contractual data protection requirements.
- Implement appropriate safeguards for PHI.

- Report incidents promptly.
- Complete security assessments or questionnaires.
- Follow minimum necessary access principles.

Healthcare examples:

- Cloud hosting providers
- Billing service vendors
- Telemedicine platform providers

Summary Table

Role	Key Responsibilities
Data Owner	Classify data, approve access, ensure compliance
Data Custodian	Implement technical controls, maintain systems
Data User	Follow handling rules, protect data, report issues
Compliance Officer	Monitor compliance, conduct audits, manage incidents
Security Team	Monitor logs, enforce security, respond to threats
Clinical Staff	Protect PHI during care delivery
Third-Party Providers	Secure data, follow contractual requirements